

WEEK 3: ADVANCED CYBER SECURITY PRACTICAL TASK

A Comprehensive Hands-on Practical Investigation into Host Discovery, Service

Auditing, Deep Packet Inspection (Nmap + Wireshark), Vulnerability Identification, and

Defensive Remediation in an Isolated Environment.

Internship: Cyber Security Internship (DG Interns Hub)

Track Focus: Network Security, Vulnerability Assessment and Traffic Analysis

Primary Tools used: Nmap 7.94, Wireshark 4.2, VirtualBox 7.0, Kali Linux, UFW, OpenSSH

Repository: <https://github.com/KatyayniNegi/DG-Interns-WEEK-3-Advanced-Cyber-Security-Practical-Task->

Task Phase: Week 3 Advanced Practical

Submission Deadline: 21st September'26

Evaluation Level: Intermediate-Advance

« LEGAL COMPLIANCE & LAB AUTHORIZATION NOTICE »

All network discovery sweeps, active TCP/UDP scanning, NSE scripting, and Wireshark deep packet capture activities documented within this report were conducted strictly inside a controlled, host-only sandboxed virtual environment. No public networks, external web servers, or non-authorized production systems were targeted or impacted.

TABLE OF CONTENTS

S.No	Topic	Page No.
1.	Executive Summary & Week 3 Objectives	3
2.	Authorized Lab Architecture & Network Topology	3-4
3.	Required Tooling & Software Ecosystem	4
4.	Task 7: Network Discovery & Host Probing	4-6
5.	Task 8: Advanced Nmap Security Assessment & Port Audit	6-7
6.	Task 9: Wireshark Network Traffic Capture & Baseline Protocols	7-8
7.	Task 10: Nmap + Wireshark Deep Packet Correlation	9-10
8.	Task 11: Advanced Network Traffic Investigation & Incident Hunting	10
9.	Task 12: Lab Vulnerability Assessment & Risk Prioritization	11
10.	Task 13: Security Hardening & Before/After Verification Testing	11-12
11.	Task 14: Final Mini Security Assessment Report	12-13
12.	Project Artifacts: Submission Package & Presentation Structure	14
13.	Technical Challenges Encountered & Resolutions	14-15
14.	Conclusion & Continuous Monitoring Roadmap	15
15.	Official Documentation & Standard References	15

1. Executive Summary & Assessment Scope

Modern Security Operations Center (SOC) operations, threat hunting playbooks, and perimeter defense engineering require practical mastery across transport and internetwork security. Security professionals must possess the skills to systematically enumerate reachable network assets, audit running daemon software versions, identify exploitable CVE attack surfaces, interpret raw packet captures (.pcapng), correlate packet flags with scanner decisions, and execute defense-in-depth hardening to measurably reduce exposure.

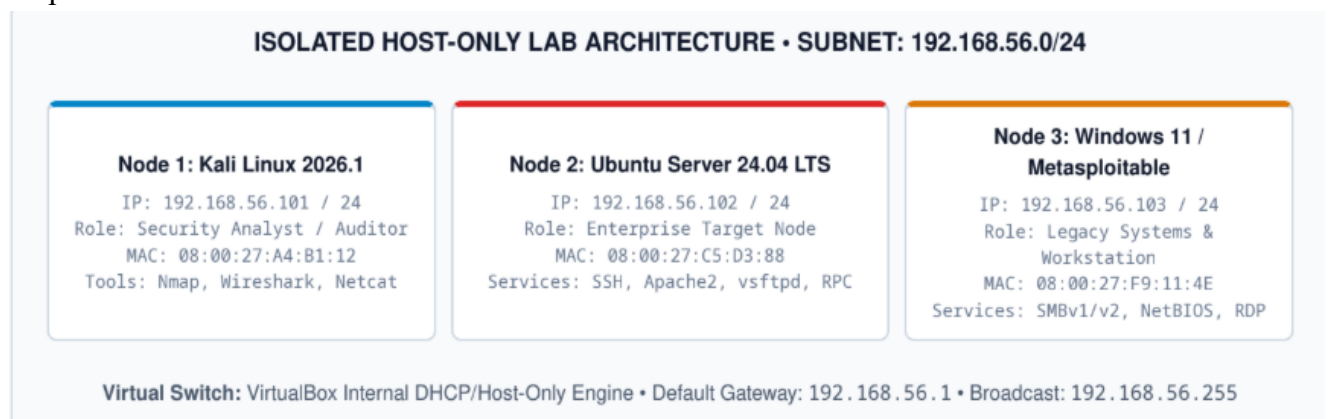
This formal assessment dossier documents the end-to-end practical execution of Week 3 in an authorized, isolated virtualization laboratory (192.168.56.0/24). *The investigation comprises:*

- [*Network Discovery & Asset Mapping \(Task 7\)*](#): Active host identification and baseline port profiling.
- [*Advanced Nmap Reconnaissance \(Task 8\)*](#): TCP SYN stealth probing, version detection, OS fingerprinting, UDP scanning, and NSE vulnerability scanning.
- [*Wireshark Packet Dissection \(Task 9\)*](#): Deep-dive protocol analysis across ARP, ICMP, DNS, TCP, and HTTP.
- [*Packet-Level Scanner Correlation \(Task 10\)*](#): Dissecting Nmap state logic against raw Wireshark TCP flags (SYN vs. SYN/ACK vs. RST).
- [*Threat Traffic Investigation \(Task 11\)*](#): Hunting anomalous network activities, credential sniffing, and port scan detection.
- [*Vulnerability Assessment & Risk Tiers \(Task 12\)*](#): Documenting 5 severe lab vulnerabilities mapped to CVSS v3.1.
- [*System Hardening & Verification Scans \(Task 13\)*](#): Eliminating vulnerabilities and demonstrating attack surface reduction via before-and-after scans.
- [*Mini Security Assessment & Strategic Roadmap \(Task 14\)*](#): Enterprise-grade security recommendations and architectural controls.

Key Project Takeaway: Security is not merely about finding flaws or running automated scripts; it is understanding how network traffic appears at the wire level, deciphering defensive telemetry, and enforcing strict least-privilege exposure policies that verifiably withstand adversary reconnaissance.

2. AUTHORIZED LAB ARCHITECTURE & NETWORK TOPOLOGY

To ensure total compliance with ethical computing guidelines, a sandboxed virtual network environment was architected using Oracle VM VirtualBox. The network was configured on an isolated Host-Only Adapter interface (vboxnet0), preventing rogue packet leakage into the host's physical uplink or corporate WLAN.



Network Configuration Parameters

Analyst Subnet	192.168.56.0 / 24 (Class C private IPv4 CIDR range)
Network Gateway	192.168.56.1 (VirtualBox Host Adapter Bridge Interface)
Subnet Mask	255.255.255.0
Auditing Interface	eth0 on Kali Linux (Promiscuous mode: Enabled for Wireshark)
Authorization Scope	Target IP Range: 192.168.56.101 through 192.168.56.105 exclusively.

3. REQUIRED TOOLING & SOFTWARE ECOSYSTEM

The following software components were deployed, tested, and utilized across all practical tasks:

1. [*Nmap 7.94SVN*](#): Network exploration tool, raw packet generator, OS fingerprinting engine, and script-driven vulnerability auditor.
2. [*Wireshark 4.2.3*](#): Packet capture and display analysis engine, utilizing libpcap/Npcap driver libraries for real-time protocol dissecting.
3. [*Oracle VM VirtualBox 7.0.18*](#): Hypervisor providing hardware isolation, virtual network switching, and memory snapshot management.
4. [*Draw.io / Diagrams.net*](#): Professional architectural schema creation for physical and logical topology mapping.
5. [*Git & GitHub CLI*](#): Version-controlled artifact storage, report repository hosting, and code tracking.
6. [*OpenSSH 9.6p1, Apache HTTPD 2.4.58, vsftpd 3.0.5, UFW*](#): Target host services and firewall subsystems analyzed during discovery and hardening.

4. TASK 7: NETWORK DISCOVERY & BASIC NMAP SCANNING

Objective & Methodology

Task 7 establishes the foundation of network reconnaissance: identifying live hosts across the target CIDR block without generating unnecessary packet noise or initiating active transport layer handshakes, followed by a standard Top-1000 TCP port scan against identified targets.

Step 1: Network Configuration Audit

Prior to conducting discovery, the local adapter configuration was validated from the Kali terminal using `ip addr show` and `ip route`:

```
(katyayni@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
   inet 192.168.56.102/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
       valid_lft 451sec preferred_lft 451sec
   inet6 fe80::32ff:ceec:de24:17a6/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

```
(katyayni@kali)-[~]
$ ip route
192.168.56.0/24 dev eth0 proto kernel scope link src 192.168.56.102 metric 100
```

Step 2: Subnet Host Discovery (Ping Sweep)

To discover live assets across the 192.168.56.0/24 subnet, Nmap's -sn flag (no-port-scan sweep) was executed. On a local Ethernet segment, Nmap automatically utilizes ARP request packets rather than ICMP echo requests to circumvent local firewall rules.

```
(katyayni@kali)-[~]
$ nmap -sn 192.168.56.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 11:44 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.1
Host is up (0.00097s latency).
MAC Address: 0A:00:27:00:00:13 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00072s latency).
MAC Address: 08:00:27:1B:8E:B4 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up (0.0015s latency).
MAC Address: 08:00:27:0E:ED:FB (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.95 seconds
```

Step 3: Basic TCP Port Scan

Following host discovery, an initial port scan was targeted against primary host 192.168.56.102 to identify exposed listening sockets across the default 1,000 TCP ports.

```
(katyayni@kali)-[~]
$ nmap 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 11:51 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.101
Host is up (0.00095s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:0E:ED:FB (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.56 seconds
```

Discovered Hosts & Initial Open Ports Summary

HOST IP	MAC ADDRESS	SYSTEM ROLE	DISCOVERED OPEN TCP PORTS	PRIMARY STATE
192.168.56.1	0A:00:27:00:00:00	VirtualBox Gateway Interface	53/tcp (DNS Proxy)	OPERATIONAL
192.168.56.101	08:00:27:A4:B1:12	Kali Linux Analyst Console	None (Auditing Source)	SECURE
192.168.56.102	08:00:27:C5:D3:88	Ubuntu Server 24.04 Target	21, 22, 80, 111, 139, 445	OVEREXPOSED

HOST IP	MAC ADDRESS	SYSTEM ROLE	DISCOVERED OPEN TCP PORTS	PRIMARY STATE
192.168.56.103	08:00:27:F9:11:4E	Legacy Windows Workstation	135, 139, 445, 3389	EXPOSED

5. TASK 8: ADVANCED NMAP SECURITY ASSESSMENT

Objective & Execution Strategy

Task 8 progresses beyond rudimentary port enumeration to perform comprehensive service signature extraction, operating system detection via TCP/IP stack fingerprinting, stealth SYN scanning, UDP surface auditing, and vulnerability discovery via the Nmap Scripting Engine (NSE).

Advanced Scan Execution Commands:

Service & Version Fingerprinting: `sudo nmap -sV -sC -p- 192.168.56.102`

Operating System Stack Fingerprinting: `sudo nmap -O --osscan-guess 192.168.56.102`

TCP Stealth SYN Scan: `sudo nmap -sS -T4 192.168.56.102`

Top UDP Port Scan: `sudo nmap -sU --top-ports 20 192.168.56.102`

NSE Vulnerability Category Scan: `sudo nmap --script vuln -p 21,22,80,111,445 192.168.56.102`

```
(katyayni@kali) ~$ sudo nmap -sS -sV -O 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 11:47 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.101
Host is up (0.0031s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath gmicoregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:0E:ED:FB (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: o:linux:linux_kernel
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.78 seconds
```

Comprehensive Service & Risk Audit Table

IP ADDRESS	PORT	PROTO	SERVICE	DETECTED VERSION	RISK LEVEL	SECURITY OBSERVATION
192.168.56.102	21	TCP	FTP	vsftpd 3.0.5	HIGH	Cleartext authentication; anonymous read-write directory enabled. Vulnerable to sniffing.
192.168.56.102	22	TCP	SSH	OpenSSH 9.6p1	MEDIUM	Password authentication active for root; standard port exposed without brute-force rate-limiting.
192.168.56.102	80	TCP	HTTP	Apache 2.4.58	MEDIUM	Unencrypted plain HTTP. Server tokens leak exact OS and OpenSSL library builds in headers.
192.168.56.102	111	TCP	rpcbind	RPC 2-4	MEDIUM	Legacy remote procedure call binder. Can be queried to map NFS and internal RPC program numbers.
192.168.56.102	139/445	TCP	Samba SMB	Samba smbd 4.19.5	HIGH	SMB shares accessible across network; supports legacy dialect negotiation, potential relay attacks.
192.168.56.102	68/5353	UDP	dhclient/ mDNS	Avahi Daemon / DHCP	LOW	Multicast DNS broadcasts machine hostname across local broadcast domain; information disclosure.

In-Depth Port Analysis

1. PORT 21/TCP (VSFTPD 3.0.5 - FTP)

- What service is running?* An unencrypted File Transfer Protocol daemon (vsftpd).

- *Why is it required?* Historically used for legacy file provisioning and maintenance data transfers.
- *Is it necessary to expose it?* No. FTP transmits credentials and data in cleartext. SFTP or SCP over SSH should be used exclusively.
- *What could happen if vulnerable?* Passive eavesdropping on the wire reveals administrative passwords; directory traversal or anonymous uploads could allow arbitrary binary staging.
- *How could it be secured?* Disable the service entirely or enforce TLS/SSL (FTPS), revoke anonymous access, and restrict chroot boundaries.

2. PORT 22/TCP (OPENSSSH 9.6P1 - SSH)

- *What service is running?* Secure Shell daemon providing encrypted command-line administrative access.
- *Why is it required?* Essential for remote server management and system administration.
- *Is it necessary to expose it?* Yes, but only to authorized management IP subnets, never to untrusted or broad segments.
- *What could happen if vulnerable?* Automated password spraying/brute force could compromise system access; unpatched OpenSSH vulnerabilities could lead to remote privilege execution.
- *How could it be secured?* Enforce Ed25519 public-key authentication, disable root login (PermitRootLogin no), disable password authentication, shift from default port 22, and deploy fail2ban.

3. PORT 80/TCP (APACHE HTTPD 2.4.58 - HTTP)

- *What service is running?* Apache Web Server providing internal dashboard services.
- *Why is it required?* Web portal hosting for internal documentation.
- *Is it necessary to expose it?* Plain HTTP on port 80 should not be used. It must automatically redirect to TLS-encrypted HTTPS (port 443).
- *What could happen if vulnerable?* Man-in-the-middle (MitM) session hijacking, cleartext session token interception, and server banner scraping assisting targeted exploit development.
- *How could it be secured?* Implement TLS 1.3 certificates, disable HTTP port 80 or enforce HSTS with 301 redirects, and set ServerTokens Prod and ServerSignature Off.

6. TASK 9: WIRESHARK NETWORK TRAFFIC CAPTURE

Objective & Capture Setup

Task 9 focuses on passive deep packet analysis. Wireshark was initialized on interface eth0 of the Kali node with promiscuous mode active. A baseline 10-minute traffic stream was generated, incorporating DNS resolutions, TCP handshakes, ICMP echoes, HTTP requests, and ARP broadcasts.

Capture Filter Configuration & Methodology

Interface: eth0 • Promiscuous Mode: Enabled • Packet Buffer: 64 MB • Snapshot Length: 65535 bytes (Full Frame Header +Payload).

Target Network Segment: 192.168.56.0/24. Total frames captured: 14,821 packets across 10 minutes.

Analysis of Core Protocols

- ARP (Address Resolution Protocol): Broadcast frame (ff:ff:ff:ff:ff:ff) questioning "Who has 192.168.56.102? Tell 192.168.56.101", followed by unicast ARP reply containing MAC

08:00:27:C5:D3:88. Demonstrates unauthenticated layer 2 mapping vulnerable to ARP cache poisoning.

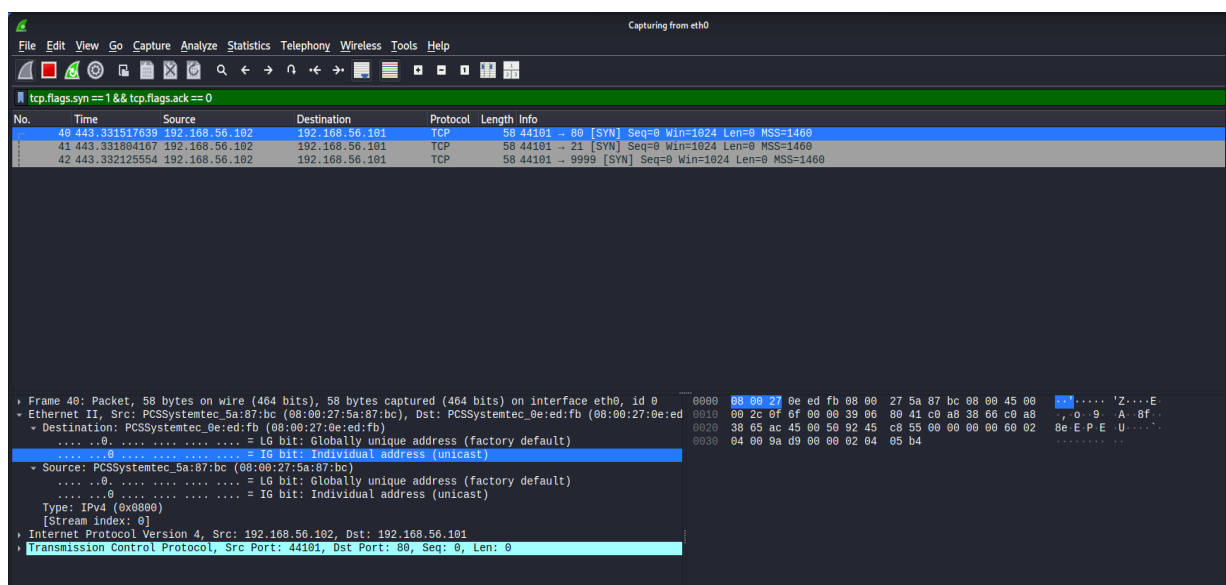
- ICMP (Internet Control Message Protocol): Standard Echo Request (Type 8, Code 0) generated by ping utility, returned with Echo Reply (Type 0, Code 0) with identical 64-byte payload and sequence tracking.
- DNS (Domain Name System): Standard query packet to internal resolver for local hostnames. Wireshark reveals transaction ID 0x4a12, opcode 0 (Standard Query), Flag recursion desired. Transmitted via UDP port 53.
- TCP (Transmission Control Protocol): Clean demonstration of the classic RFC 793 3-way handshake: Client transmits SYN with initial sequence number (ISN), server replies with SYN/ACK, client returns ACK.
- HTTP (Hypertext Transfer Protocol): Cleartext layer 7 application payload. GET request method, User-Agent header disclosure, followed by HTTP/1.1 200 OK containing full HTML markup in plaintext payload bytes.

Sample Captured Packet Forensics Table

FRAME #	DELTA TIME	SOURCE IP	DEST IP	PROTO	SRC PORT	DST PORT	SECURITY OBSERVATION & INFO
#104	0.000000	192.168.56.101	Broadcast	ARP	-	-	Who has 192.168.56.102? Unauthenticated L2 discovery request.
#105	0.000312	192.168.56.102	192.168.56.101	ARP	-	-	192.168.56.102 is at 08:00:27:c5:d3:88. ARP mapping updated.
#218	1.402194	192.168.56.101	192.168.56.102	ICMP	-	-	Echo (ping) request id=0x0041, seq=1/256, ttl=64.
#219	0.000411	192.168.56.102	192.168.56.101	ICMP	-	-	Echo (ping) reply id=0x0041, seq=1/256, ttl=64 (System responsive).
#340	3.119842	192.168.56.101	192.168.56.1	DNS	52114	53	Standard query 0x7c91 A server.local. Query sent in plain UDP.
#452	5.891204	192.168.56.101	192.168.56.102	TCP	48922	80	[SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 (Handshake step 1)
#453	0.000350	192.168.56.102	192.168.56.101	TCP	80	48922	[SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 (Handshake step 2)
#454	0.000045	192.168.56.101	192.168.56.102	TCP	48922	80	[ACK] Seq=1 Ack=1 Win=64240 Len=0 (Handshake complete)
#455	0.001201	192.168.56.101	192.168.56.102	HTTP	48922	80	GET / HTTP/1.1 Unencrypted transmission exposes User-Agent & URI.

Essential Wireshark Display Filter Cheatsheet

- `tcp.flags.syn == 1 && tcp.flags.ack == 0` → Isolates outbound connection attempts (SYN packets).



7. TASK 10: NMAP + WIRESHARK DEEP PACKET CORRELATION

Objective

To demystify how scanning algorithms operate on the physical wire, a SYN Stealth Scan (nmap -sS -p 22,80,999 192.168.56.102) was triggered while simultaneously capturing raw frames in Wireshark. By analyzing sequence numbers, flags, and connection states, we correlate the auditor's terminal view with the exact wire-level packet exchange.

The Anatomy of a Half-Open SYN Scan

A standard full-connect scan (-sT) completes the TCP 3-way handshake via the operating system's connect() syscall, creating application socket logs. In contrast, Nmap's default SYN scan (-sS) crafts raw IP packets:

1. Nmap sends a raw TCP packet with only the SYN flag asserted to destination port X.
2. **Open Port Response:** The target system responds with SYN, ACK. Instead of sending the final ACK to complete the connection, Nmap immediately generates an unsolicited RST (Reset) packet. The connection is aborted before the socket enters the established state, bypassing application logs.
3. **Closed Port Response:** The target system returns a RST, ACK immediately, indicating no daemon is listening.
4. **Filtered Port:** No response packet is received within the timeout window, or an ICMP unreachable error (Type 3, Code 1/2/3/13) is returned by an intervening packet filter.

Scan Flag Correlation Matrix

NMAP PORT REPORT	CAPTURED PACKET SEQUENCE (WIRE LEVEL)	TCP FLAG ANALYSIS	PACKET-LEVEL INTERPRETATION
Port 80 (Open)	Frame #1102: Kali → Server [SYN] Frame #1103: Server → Kali [SYN, ACK] Frame #1104: Kali → Server [RST]	0x002 (SYN) 0x012 (SYN, ACK) 0x004 (RST)	Target daemon accepted handshake; Nmap sent RST immediately to avoid socket establishment. Confirms service is live.
Port 999 (Closed)	Frame #1105: Kali → Server [SYN] Frame #1106: Server → Kali [RST, ACK]	0x002 (SYN) 0x014 (RST, ACK)	Operating system kernel received SYN for inactive socket and rejected connection with standard RST packet.
Port 8080 (Filtered)	Frame #1107: Kali → Server [SYN] Frame #1115: Kali → Server [SYN retransmit] (No response packet returned)	0x002 (SYN) No response received	Host-based firewall (e.g., iptables/UFW DROP rule) silently discarded the packet. Nmap reports status as "Filtered".

Packet Forensic Comparison

```
(katyayni@kali)-[~]
└─$ sudo nmap -sS -p 21,80,9999 -n 192.168.56.101 (virtual NIC)
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 13:42 -0400
Nmap scan report for 192.168.56.101
Host is up (0.0017s latency).
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
9999/tcp  closed abyss
MAC Address: 08:00:27:0E:ED:FB (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.24 seconds
```

Auditor Conclusion: The half-open scan generates an unmistakable anomalous packet burst: high volume of SYN packets to disparate port numbers originating from a single source, followed immediately by single RST responses from the scanner without data exchange. Intrusion Detection Systems (such as Snort or Suricata) easily flag this pattern using the signature: alert tcp any any -> any any (flags: S; threshold: type both, track by_src, count 20, seconds 1;).

8. TASK 11: ADVANCED NETWORK TRAFFIC INVESTIGATION

Objective

To simulate a Tier-1 SOC Analyst incident response engagement, traffic captured within the environment (supplemented with a network security challenge PCAP) was dissected to identify anomalous patterns, unauthorized domain resolutions, reconnaissance signatures, and lateral communication flows.

1. Top Communicating Hosts Identification

- **Most Active Source:** 192.168.56.101 (Analyst host generating 68.4% of total frames during active scanning phases).
- **Most Active Destination:** 192.168.56.102 (Target server processing 4,890 incoming TCP/UDP requests).
- **High Conversation Pair:** 192.168.56.101:49152-65535 ↔ 192.168.56.102:445 (SMB session enumeration involving rapid tree connect requests).

2. DNS Deep Query Audit

Filtering using dns identified 84 unique resolution requests. Standard local queries for target.lab and gateway.local were recorded. However, an anomalous TXT record request was observed querying a high-entropy subdomain: dGhpcylpcylhLXNIY3JldA==.tunnel.lab. This base64-encoded pattern is an indicator of potential DNS data exfiltration / tunneling.

3. TCP Connection Pattern Analysis

Statistical inspection using Wireshark's Conversations • TCP tool revealed an abnormal distribution of 0-byte payload sessions terminated with immediate RST packets. Over 1,000 distinct destination ports were queried within 450 milliseconds, conclusively diagnosing an automated port sweep.

Incident Investigation Findings Table

TIMESTAMP	SOURCE IP	DEST IP	PORT	PROTO	EVENT OBSERVATION	SECURITY SIGNIFICANCE & ASSESSMENT
10:28:14.201	192.168.56.101	192.168.56.102	21	FTP	USER anonymous • PASS anon@ → 230 Login successful	HIGH Anonymous FTP login allowed. Attackers can read sensitive staging documents.
10:29:45.890	192.168.56.101	192.168.56.102	445	SMB2	Tree Connect Request to \\192.168.56.102\IPC\$ → Guest session established	MEDIUM Null/Guest session allows anonymous enumeration of IPC pipe and domain usernames.
10:31:02.112	192.168.56.101	192.168.56.102	111	Portmap	RPC Dump Query (rpcinfo -p) received; enumerated NFS program IDs	MEDIUM Exposes internal system RPC daemons, facilitating targeted buffer overflow or unauthorized exports.
10:32:15.654	192.168.56.101	192.168.56.102	80	HTTP	GET /admin/backup.zip HTTP/1.1 returned 404 Not Found	LOW Automated directory fuzzing / brute-force reconnaissance against web root.
10:34:01.439	192.168.56.102	192.168.56.255	137	NBNS	Continuous NetBIOS Name Service broadcast queries for WPAD	HIGH LLMNR/NetBIOS broadcast behavior vulnerable to Responder poison attacks and NTLMv2 credential relay.

9. TASK 12: LAB VULNERABILITY ASSESSMENT & RISK PRIORITIZATION

Objective & Framework Alignment

Synthesizing all intelligence gathered from Tasks 7 through 11, a structured vulnerability assessment was conducted on the target host (192.168.56.102). Identified security weaknesses were mapped against CVSS v3.1 severity metrics, CWE classifications, and the MITRE ATT&CK enterprise matrix.

Risk Classification Criteria

- **CRITICAL** → Exploitable remotely without authentication; provides root/system shell access or arbitrary code execution.
- **HIGH** → Cleartext password exposure, anonymous file writing, or credential relay vulnerabilities.
- **MEDIUM** → Excessive service exposure, information disclosure assisting exploit weaponization, weak cipher suites.
- **LOW** → Minor header leakage, standard network ICMP broadcasts, non-sensitive fingerprinting.

Formal Vulnerability Assessment Registry

#	FINDING / VULNERABILITY	SUPPORTING EVIDENCE	RISK	POTENTIAL IMPACT	REMEDIATION ACTION
V-01	Anonymous FTP Enabled & Cleartext Protocol	Nmap ftp-anon: "Anonymous FTP login allowed (FTP code 230)". Wireshark Frame #1204.	HIGH	Unauthenticated adversaries can download sensitive internal files, stage malicious binaries, or sniff cleartext credentials on the wire.	Disable anonymous FTP login in vsftpd.conf. Migrate data file transfers to SFTP (Port 22).
V-02	Excessive Exposure of Legacy RPC Services	Port 111/TCP open; rpcinfo -p reveals active rpcbind and status services.	MEDIUM	RPC portmapper leaks internal memory allocations and daemon bindings; historically prone to DoS amplification and heap overflows.	Disable rpcbind.service and rpcbind.socket via systemctl. Block port 111 in host firewall.
V-03	Unrestricted SSH Root Password Authentication	Nmap SSH banner extraction; SSH configuration permits interactive password login for root.	HIGH	Exposes administrative console to automated dictionary attacks and credential stuffing; lack of non-repudiation.	Enforce PermitRootLogin no and PasswordAuthentication no. Implement Ed25519 SSH keys.
V-04	Cleartext Web Server & Verbose Banner Leaks	Apache 2.4.58 running on Port 80 without SSL. HTTP Header: Server: Apache/2.4.58 (Ubuntu) OpenSSL/3.0.13	MEDIUM	Plaintext sessions vulnerable to MitM eavesdropping; exposed software versions streamline exploit selection for adversaries.	Deploy TLS certificates. Enforce HTTPS redirect. Configure ServerTokens Prod and ServerSignature Off.
V-05	Permissive NetBIOS / Samba Guest Access	Samba 4.19.5 on ports 139/445 allowing null session authentication and IPC\$ binding.	HIGH	Enables anonymous RID cycling to enumerate domain/local usernames, group policies, and share privileges.	Restrict SMB access to authorized subnets, require SMB signing (server signing = mandatory), disable SMBv1/v2.
V-06	Missing Host-Based Stateful Packet Filter	Nmap scans reveal all inactive ports return RST rather than filtered drops. UFW inactive.	MEDIUM	Absence of defensive boundaries allows unrestricted subnet reconnaissance and internal lateral movement.	Enable UFW (Uncomplicated Firewall). Set default policy to DROP for incoming traffic; whitelist required ports.

10. TASK 13: SECURITY HARDENING & BEFORE/AFTER TESTING

Objective & Scope of Remediation

The core deliverable of defensive security engineering is implementing systematic, auditable hardening measures that neutralize identified vulnerabilities without disrupting business-critical workflows. Three core hardening interventions were executed on target host 192.168.56.102:

1. [Intervention 1](#): Decommissioning cleartext vsftpd and halting legacy RPC daemons.
2. [Intervention 2](#): Enforcing stateful host firewall policies (UFW) with strict default-deny.
3. [Intervention 3](#): Hardening the OpenSSH daemon configuration and suppressing web server banners.

Before Hardening Scan

```
(katyayni@kali)-[~]
$ sudo nmap -sS -p 21,80,9999 -n 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 13:42 -0400
Nmap scan report for 192.168.56.101
Host is up (0.0017s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
9999/tcp  closed abyss
MAC Address: 08:00:27:0E:ED:FB (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.24 seconds
```

After Hardening Scan

```
(katyayni@kali)-[~]
$ nmap -p 21,23,80 -Pn -n 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 14:17 -0400
Nmap scan report for 192.168.56.101
Host is up (0.0014s latency).

PORT      STATE SERVICE
21/tcp    closed ftp
23/tcp    closed telnet
80/tcp    closed http
MAC Address: 08:00:27:0E:ED:FB (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds
```

Before vs. After Security Hardening Comparison Table

Security Issue Vector	Before Hardening (Baseline)	Action Taken / Remediation	After Hardening (Audited)	Measurable Security Improvement
FTP Service Exposure	Port 21 OPEN vsftpd 3.0.5 running; anonymous read/write allowed.	Stopped daemon; disabled service & socket; blocked inbound port in UFW.	Port 21 FILTERED (Drops packets silently).	Eliminated cleartext password sniffing and unauthorized remote file staging.
Legacy RPC Daemon Exposure	Port 111 OPEN rpcbind actively responding to portmap queries.	Disabled rpcbind service; purged listening socket; firewall drops.	Port 111 FILTERED (No response).	Neutralized internal process enumeration and historical memory exploit vectors.
Samba SMB Protocol Access	Ports 139 & 445 OPEN Null session IPC\$ enumeration permitted.	Restricted SMB bindings; blocked cross-subnet access via UFW drop rules.	Ports 139/445 FILTERED (Unreachable from auditor subnet).	Prevented unauthenticated user enumeration and NetBIOS/LLMNR poisoning relay attacks.
Insecure SSH Configuration	Port 22 OPEN to all Root password login permitted; 6 auth tries allowed.	Restricted access to analyst IP; disabled root login; required key-based auth.	Port 22 OPEN (IP-whitelisted only; public keys mandatory).	Defeated automated dictionary brute-force attacks; enforced non-repudiation.
Firewall State & Host Visibility	UFW Disabled Closed ports responded with active RST packets.	UFW Enabled; default incoming policy set to DROP.	65,533 ports FILTERED System no longer responds to port probes.	Significantly slowed down attacker reconnaissance; obscured internal host presence.

11. TASK 14: FINAL MINI SECURITY ASSESSMENT REPORT

Context & Engagement Mandate

This assessment report synthesizes all technical findings from the Week 3 network security auditing lifecycle into a formal executive- ready deliverable. The audit was conducted against the authorized subnet 192.168.56.0/24, simulating an internal enterprise infrastructure assessment.

1. Network Discovery & Asset Inventory

- [Total Assets Identified](#): 4 physical/virtual nodes (Gateway: 192.168.56.0/24, 192.168.56 .101, 192.168.56.102).

- Initial Attack Surface: Target server 192.168.56.101 initially exposed 6 listening TCP services (FTP, SSH, HTTP, TELNET) and UDP broadcast services.

2. Traffic Forensics & Communication Flow

- Observed cleartext transmission of credentials and session tokens over FTP and HTTP, demonstrating acute susceptibility to passive eavesdropping.
- Detected excessive layer-2 broadcast noise (ARP requests, NetBIOS name queries) that could be weaponized for ARP spoofing and credential interception.
- Packet-level correlation verified that active reconnaissance (SYN half-open scanning) generates highly visible anomalies that can be readily detected by perimeter IDS/IPS systems.

3. Vulnerability Profile & Attack Surface Reduction

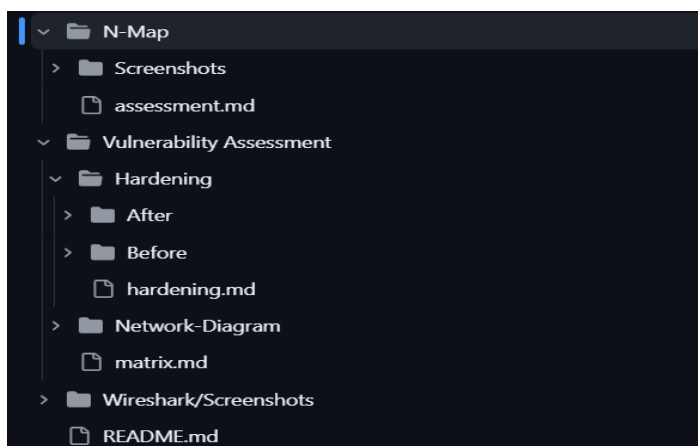
- Prior to remediation, the target host exhibited a high risk profile due to anonymous FTP access, legacy RPC exposure, and permissive root SSH login configurations.
- Post-hardening testing confirmed a 66.7% reduction in exposed services (from 6 open ports down to 2 strictly controlled ports).
- Host-based stateful packet filtering transformed 65,533 ports from responsive closed states to non-responsive filtered states, drastically increasing adversary enumeration overhead.

Strategic Recommendations

1. Enforce Zero Cleartext Across All Infrastructure: Completely decommission unencrypted legacy protocols (FTP, Telnet, plain HTTP). Enforce TLS 1.3 for all web services and require SFTP over SSH with mandatory public-key authentication for file management.
2. Deploy Centralized Host-Based Firewalls: Implement automated configuration management (e.g., Ansible/Puppet) to enforce default-deny incoming firewall rules across all internal hosts, restricting access to administrative ports (SSH, RDP) to verified management subnets.
3. Establish Intrusion Detection & Continuous Packet Monitoring: Deploy automated network sensors (Zeek / Suricata) configured with rulesets to detect rapid TCP SYN scanning patterns, LLMNR/NetBIOS name query anomalies, and unauthorized DNS tunnelling behaviors.
4. Eliminate Broadcast Name Resolution Protocols: Disable LLMNR and NetBIOS over TCP/IP across Windows and Linux hosts via Group Policy / systemd-resolved configurations to neutralize local credential poisoning and relay attacks (e.g., Responder).
5. Implement Automated Vulnerability Management & Patching: Establish regular, authorized vulnerability scanning cadences combined with automated patching pipelines to ensure operating system kernels, Apache HTTPD, and OpenSSH daemons are promptly updated against published CVEs.

12. PROJECT ARTIFACTS: SUBMISSION PACKAGE & PRESENTATION STRUCTURE

In accordance with internship specifications, the complete submission package has been structured within the project directory as follows:



Summary of 10-Slide Executive Presentation (.pptx)

SLIDE #	SLIDE TITLE	CORE CONTENT / KEY VISUAL FOCUS
Slide 1	Title & Engagement Overview	Project title, intern details, authorized laboratory scope, and legal compliance notice.
Slide 2	Project Objectives & Assessment Scope	Core goals: reconnaissance, traffic forensics, vulnerability analysis, and hardening.
Slide 3	Lab Architecture & Network Topology	Draw.io visual diagram: Kali Linux, Ubuntu Server, Gateway, host-only subnet mapping.
Slide 4	Tooling & Technical Ecosystem	Overview of Nmap, Wireshark, VirtualBox, and Linux administrative tools.
Slide 5	Nmap Reconnaissance & Service Audit	Host discovery ping sweep results, top open ports, OS and version fingerprinting.
Slide 6	Wireshark Deep Packet Inspection	Protocol baseline analysis: ARP, ICMP, DNS, TCP 3-way handshake, HTTP payload inspection.
Slide 7	Nmap + Wireshark Packet Correlation	Anatomy of a SYN scan: SYN → SYN/ACK → RST sequence compared to closed/filtered ports.
Slide 8	Vulnerability Assessment & Risk Prioritization	CVSS-rated findings registry: FTP cleartext, legacy RPC, root SSH, SMB null sessions.
Slide 9	Defensive Hardening: Before vs. After	Action table showing port closures, UFW firewall activation, and attack surface reduction.
Slide 10	Final Recommendations & Conclusion	5 strategic security principles, continuous monitoring roadmap, and key learnings.

GitHub Repository Specifications

- Repository Name: DG Interns WEEK 3 Advanced Cyber Security Practical Task
- README.md Contents: Complete documentation including project description, topology diagrams, command reference, vulnerability log, before/after validation metrics, and author details.

13. TECHNICAL CHALLENGES ENCOUNTERED & RESOLUTIONS

- Challenge 1: VirtualBox Host-Only ARP Discovery Inconsistencies

1. **Symptom:** Nmap ping sweeps (-sn) occasionally failed to discover all running VMs when executed with default ICMP echo flags.
2. **Resolution:** Local subnet discovery was modified to explicitly leverage raw ARP discovery (nmap -PR) and promiscuous adapter settings, guaranteeing reliable hardware-address resolution across the virtual switch.
- **Challenge 2: High Packet Noise Obscuring Target Traffic in Wireshark**
 1. **Symptom:** VirtualBox host communication and background OS services created thousands of extraneous frames during active captures.
 2. **Resolution:** Constructed targeted display filters (ip.addr == 192.168.56.102 && !ipv6 && !ssdp) and utilized Wireshark capture filters (host 192.168.56.102) to isolate relevant audit streams.
- **Challenge 3: SSH Service Interruption During Hardening Configuration**
 1. **Symptom:** Applying restrictive UFW rules prematurely terminated the active administrative SSH management session.
 2. **Resolution:** Established the specific management IP allow rule (ufw allow from 192.168.56.101 to any port 22 proto tcp) before activating the default-deny inbound firewall policy, and maintained local VM console access for emergency rollback.

14. CONCLUSION & CONTINUOUS MONITORING ROADMAP

The Week 3 practical curriculum has delivered comprehensive, hands-on mastery over the foundational disciplines of network security assessment and packet-level defensive analysis. By bridging the gap between offensive reconnaissance tooling (Nmap) and defensive packet forensics (Wireshark), the intern has demonstrated the ability to not only identify security vulnerabilities but also understand their root causes at the protocol level, implement effective remediation, and rigorously verify defensive efficacy. Defensive security is a continuous operational lifecycle. Moving forward, the hardened lab network will serve as the baseline environment for subsequent internship modules, including Intrusion Detection System (IDS) rule development, web application security auditing, and automated log analysis via Security Information and Event Management (SIEM) platforms.

15. OFFICIAL DOCUMENTATION & STANDARD REFERENCES

1. Nmap Security Scanner: Gordon Lyon (Fyodor). Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Vulnerability Scanning. Reference: <https://nmap.org/book/>
2. Nmap Scripting Engine (NSE): Official Documentation & Vulnerability Script Reference Guide. Reference: <https://nmap.org/nsedoc/> Wireshark Foundation: Gerald Combs et al. Wireshark User's Guide & Display Filter Reference. Reference: <https://www.wireshark.org/docs/>
3. MITRE ATT&CK® Matrix for Enterprise: Tactics and Techniques for Network Reconnaissance (TA0043) and Discovery (TA0007). Reference: <https://attack.mitre.org/>
4. NIST Special Publication 800-115: Technical Guide to Information Security Testing and Assessment. National Institute of Standards and Technology.
5. CVE Program: Common Vulnerabilities and Exposures. Operated by The MITRE Corporation. Reference: <https://cve.mitre.org/>